

Part 1: Introduction to Cybersecurity

- What is Cybersecurity?
- Importance of Cybersecurity
- Goals of Cybersecurity (CIA + Authentication + Authorization)
- Types of Cybersecurity
- Cyber Threat Landscape
- Common Cyber Attacks
- Basic Security Terminologies
- History and Evolution of Cybersecurity

Part 2: CIA Triad

- ◇ Introduction to the CIA Triad
- ◇ Confidentiality
- ◇ Integrity
- ◇ Availability
- ◇ Authentication vs Authorization
- ◇ Non-repudiation
- ◇ Access Control
- ◇ Encryption
- ◇ Hashing
- ◇ Digital Signatures
- ◇ Real-world Examples

◇ Review Questions

Part 3: Malware & Ransomware

◇ What is Malware?

◇ Virus

◇ Worm

◇ Trojan Horse

◇ Spyware

◇ Adware

◇ Rootkits

◇ Keyloggers

◇ Botnets

◇ Ransomware

◇ Fileless Malware

◇ Malware Analysis Basics

◇ Prevention & Detection

◇ Review Questions

Part 4: Threat Actors & Attack Vectors

◇ Threat Actors

◇ Hackers (White, Black, Gray Hat)

◇ Insider Threats

◇ Nation-State Attacks

◇ Cybercriminal Organizations

- ◇ Attack Vectors
- ◇ Phishing
- ◇ Social Engineering
- ◇ Password Attacks
- ◇ Web Attacks
- ◇ Network Attacks
- ◇ Review Questions

Part 5: Cyber Kill Chain

- ◇ What is the Cyber Kill Chain?
- ◇ Reconnaissance
- ◇ Weaponization
- ◇ Delivery
- ◇ Exploitation
- ◇ Installation
- ◇ Command & Control (C2)
- ◇ Actions on Objectives
- ◇ MITRE ATT&CK Overview
- ◇ Detection Opportunities
- ◇ Review Questions

Part 6: Real-World Case Studies

- ◇ WannaCry

- ◇ NotPetya
- ◇ Stuxnet
- ◇ SolarWinds
- ◇ Equifax Data Breach
- ◇ Colonial Pipeline
- ◇ Yahoo Data Breach
- ◇ Lessons Learned
- ◇ Incident Response
- ◇ Review Questions

Part 7: Defense in Depth & Security Best Practices

- ◇ Defense in Depth
 - ◇ Layered Security
 - ◇ Firewalls
 - ◇ Antivirus & EDR
 - ◇ IDS & IPS
 - ◇ VPN
 - ◇ Multi-Factor Authentication (MFA)
 - ◇ Zero Trust
 - ◇ Network Segmentation
 - ◇ Security Policies
 - ◇ Security Awareness Training
 - ◇ Backup & Disaster Recovery

- ◇ Incident Response
- ◇ Security Auditing
- ◇ Best Practices
- ◇ Final Review

Introduction to Cybersecurity

1. Definition

Cybersecurity is the practice of protecting computers, networks, devices, and data from cyber attacks, unauthorized access, theft, or damage.

Simple: Cybersecurity = Protecting digital systems and information.

2. Why Cybersecurity is Important

Cybersecurity protects important systems such as:

- Banking
- Hospitals
- Government
- Schools
- Businesses
- Social Media

Without cybersecurity:

- ◇ Data can be stolen.
- ◇ Money can be lost.
- ◇ Systems may stop working.

- ◇ Personal information can leak.

3. Components of Cybersecurity

Cybersecurity combines:

- ◇ Technology
- ◇ Processes
- ◇ Policies
- ◇ Human Awareness

4. Main Goals (CIA + AA)

Goal	Meaning
Confidentiality	Keep information secret.
Integrity	Keep information accurate.
Availability	Make systems available when needed.
Authentication	Verify user identity.
Authorization	Allow only authorized actions.

5. Types of Cybersecurity

- ◇ Network Security
- ◇ Application Security
- ◇ Information Security
- ◇ Cloud Security

- ◇ Mobile Security
- ◇ Endpoint Security
- ◇ IoT Security
- ◇ Operational Security (OPSEC)

6. Common Cyber Threats

- ◇ Malware
- ◇ Phishing
- ◇ Ransomware
- ◇ Password attacks
- ◇ Social engineering
- ◇ DoS/DDoS attacks

7. Common Security Tools

- ◇ Firewall
- ◇ Antivirus
- ◇ Encryption
- ◇ Multi-Factor Authentication (MFA)
- ◇ Virtual Private Network (VPN)

8. Best Practices

- ◇ Use strong passwords.
- ◇ Enable MFA.

- ◇ Update software regularly.
- ◇ Avoid suspicious links and emails.
- ◇ Back up important data.
- ◇ Install antivirus software.

Part 2: CIA Triad

1. Introduction to the CIA Triad

The **CIA Triad** is the **foundation of cybersecurity**. It consists of **three core security principles** used to protect information and systems.

The three principles are:

- **Confidentiality**
- **Integrity**
- **Availability**

These principles help ensure that information is **secure, accurate, and available** to authorized users.

2. Confidentiality (C)

Meaning

Only **authorized users** can access confidential information.

Purpose

Protect sensitive data from unauthorized access.

Examples

- ◇ Passwords
- ◇ Encryption
- ◇ Access Control
- ◇ Multi-Factor Authentication (MFA)

Example: Only the account owner can view their online banking information.

3. Integrity (I)

Meaning

Data should remain **accurate, complete, and unchanged** unless modified by an authorized user.

Purpose

Prevent unauthorized changes to data.

Examples

- ◇ Hashing
- ◇ Checksums
- ◇ Digital Signatures

Example: A student's grades should not be changed by anyone except an authorized teacher.

4. Availability (A)

Meaning

Systems and data should be **available whenever authorized users need them**.

Purpose

Ensure services continue to operate.

Examples

- ◇ Backups
- ◇ Redundant Servers
- ◇ UPS (Uninterruptible Power Supply)
- ◇ Cloud Backup

* 3-2-1 Backup Rule (Availability)

The **3-2-1 Backup Rule** is a **best practice for ensuring Availability** in cybersecurity. It helps protect data from hardware failure, accidental deletion, ransomware, and disasters.

What is the 3-2-1 Rule?

- **Keep 3 copies of your data**
 - ◇ 1 original copy

◇ 2 backup copies

- **Store the copies on 2 different types of storage**

◇ Example:

- Internal hard drive

- External hard drive

- Cloud storage

- **Keep 1 copy off-site**

◇ Store one backup in a different location, such as:

- Cloud storage

- Another office

- A secure data center

Example

Suppose you have an important project:

◇ **Original:** On your laptop

◇ **Backup 1:** On an external hard drive

◇ **Backup 2:** In cloud storage (Google Drive, OneDrive, Dropbox, etc.)

If your laptop is stolen or infected with ransomware, you can restore your files from the backup.

Why is it Important?

The 3-2-1 rule helps:

◇  Prevent data loss

◇  Recover from ransomware attacks

◇  Recover from hardware failures

◇  Recover from natural disasters (fire, flood, theft)

◇  Ensure **Availability** of data

Relation to the CIA Triad

CIA Principle	How the 3-2-1 Rule Helps
Confidentiality	Not the main purpose, but encrypted backups can protect privacy.
Integrity	Helps restore correct, uncorrupted data from backups.
Availability	Main purpose: Ensures data is available even if the original is lost or damaged.

Memory Trick

3-2-1 = 3 Copies • 2 Storage Types • 1 Off-site Backup

Example:

Laptop (Original) → External Hard Drive (Backup) → Cloud Storage (Off-site Backup)

Exam Tip: If you're asked how to ensure **Availability** in the CIA Triad, mentioning the **3-2-1 Backup Rule** is an excellent answer because it is a widely accepted backup strategy.

Example: A hospital system should be available 24/7.

5. Authentication vs Authorization

Authenti- cation	Authoriz- ation
Verifies who you are	Determin- es what you can do
Happens before access	Happens after login
Example: Login with password	Example: Read, write, or delete files

Easy Example

- ◇ Authentication = Showing your student ID.
- ◇ Authorization = Being allowed to enter the laboratory.

6. Non-repudiation

Meaning

Ensures that a person **cannot deny** performing an action.

Purpose

Provide proof of an action or transaction.

Examples

- ◇ Digital Signatures
- ◇ Signed Emails
- ◇ Transaction Logs

Example: A customer cannot deny sending an online payment after digitally signing the transaction.

7. Access Control

Meaning

Controls **who can access** resources and **what actions they can perform**.

Types

- ◇ Read
- ◇ Write
- ◇ Edit
- ◇ Delete
- ◇ Execute

Example

- ◇ Student → View grades only.
- ◇ Teacher → Add and edit grades.
- ◇ Administrator → Full access.

8. Encryption

Meaning

Encryption converts **readable data (plaintext)** into **unreadable data (ciphertext)** to protect it.

Purpose

Keep information confidential.

Example

Plaintext

Hello



Encryption



Ciphertext

X9@Lm#7!

Only someone with the correct **key** can decrypt and read the data.

9. Hashing

Meaning

Hashing converts data into a **fixed-length value (hash)**.

Purpose

Verify data integrity.

Features

- ◇ One-way process (cannot be reversed).
- ◇ Same input always produces the same hash.
- ◇ A small change in data creates a completely different hash.

Example

Password
hello123



Hash



A94A8FE5CC...

Common uses:

- ◇ Password storage
- ◇ File verification

10. Digital Signatures

Meaning

A digital signature proves that a message or file is **authentic** and **has not been modified**.

Provides

- ◇ Authentication
- ◇ Integrity
- ◇ Non-repudiation

Example

Signing a PDF document digitally before sending it.

11. Real-World Examples

Online Banking

- ◇ Confidentiality → Customer data is encrypted.
- ◇ Integrity → Transactions cannot be altered.
- ◇ Availability → Banking services are available 24/7.

Hospital

- ◇ Confidentiality → Only doctors access patient records.
- ◇ Integrity → Medical records remain accurate.
- ◇ Availability → Patient records are always accessible during emergencies.

Email

- ◇ Encryption protects email content.
- ◇ Digital signatures verify the sender.
- ◇ Hashing checks that attachments are unchanged.

FINAL

CIA Triad

- ◇ **Confidentiality** → Keep data secret.
- ◇ **Integrity** → Keep data accurate.
- ◇ **Availability** → Keep systems available.

Other Important Concepts

- ◇ **Authentication** → Verify identity.
- ◇ **Authorization** → Grant permissions.
- ◇ **Non-repudiation** → Prevent denial of actions.
- ◇ **Access Control** → Control user permissions.
- ◇ **Encryption** → Protect data confidentiality.
- ◇ **Hashing** → Verify data integrity.
- ◇ **Digital Signatures** → Provide authenticity, integrity, and non-repudiation.

Memory Tips

CIA

- ◇ **C** → Confidentiality
- ◇ **I** → Integrity
- ◇ **A** → Availability

Authentication vs Authorization

- ◇ **Authentication = Who are you?**
- ◇ **Authorization = What are you allowed to do?**

Encryption vs Hashing

- ◇ **Encryption** → Protects data by making it unreadable and can be **decrypted** with a key.
- ◇ **Hashing** → Creates a fixed fingerprint of data and **cannot be reversed**.

Part 3: Malware & Ransomware

1. What is Malware?

Malware (Malicious + Software) is software designed to **damage, steal, spy on, or disrupt** computers, networks, or data without the user's permission.

Purpose

- Steal information
- Damage files
- Spy on users
- Gain unauthorized access
- Disrupt computer systems

2. Virus

Meaning

A **virus** is malware that **attaches itself to a file or program** and spreads when the infected file is opened.

Characteristics

- ◇ Requires user action to spread.
- ◇ Can delete or corrupt files.
- ◇ Slows down computers.

Example

An infected USB drive spreads a virus to another computer.

3. Worm

Meaning

A **worm** is malware that **spreads automatically** through networks without user action.

Characteristics

- ◇ Does not need a host file.
- ◇ Spreads very quickly.
- ◇ Consumes network resources.

Example

A worm infects every computer on the same network.

4. Trojan Horse

Meaning

A **Trojan Horse** is malware that **pretends to be legitimate software** to trick users into installing it.

Characteristics

- ◇ Disguised as useful software.
- ◇ Creates backdoors for attackers.
- ◇ Can steal personal information.

Example

A fake game secretly installs malware.

5. Spyware

Meaning

Spyware secretly **collects information** about a user.

It may collect:

- ◇ Passwords
- ◇ Browsing history
- ◇ Banking information

Example

Software that records everything you type.

6. Adware

Meaning

Adware automatically displays unwanted advertisements.

Effects

- ◇ Pop-up ads
- ◇ Browser redirects
- ◇ Slower computer performance

Example

A free application that constantly shows ads.

7. Rootkits

Meaning

A **rootkit** hides malware and gives attackers **administrator (root) access** to a system.

Characteristics

- ◇ Difficult to detect.
- ◇ Hides malicious files and processes.

Example

An attacker secretly controls a computer without the user's knowledge.

8. Keyloggers

Meaning

A **keylogger** records every key pressed on the keyboard.

Purpose

Steal:

- ◇ Passwords
- ◇ Credit card numbers
- ◇ Login credentials

Example

Recording a user's online banking password.

9. Botnets

Meaning

A **botnet** is a group of infected computers controlled by an attacker.

Uses

- ◇ DDoS attacks
- ◇ Spam emails

- ◇ Cryptocurrency mining

Example

Thousands of infected computers attack one website at the same time.

10. Ransomware

Meaning

Ransomware encrypts files and demands payment (ransom) to restore access.

Famous Examples

- ◇ WannaCry

- ◇ NotPetya

Effects

- ◇ Files become inaccessible.

- ◇ Businesses may stop operating.

- ◇ Data may be permanently lost if no backup exists.

11. Fileless Malware

Meaning

Fileless malware runs **in memory (RAM)** instead of installing files on the hard drive.

Characteristics

- ◇ Hard to detect.

- ◇ Uses legitimate system tools.

- ◇ Leaves few traces.

Example

Malware that uses PowerShell commands to attack a system.

12. Malware Analysis Basics

Malware analysis is the process of studying malware to understand **how it works** and **how to stop it**.

Goals

- ◇ Identify malware type.
- ◇ Understand its behavior.
- ◇ Find indicators of compromise (IOCs).
- ◇ Develop detection and removal methods.

Basic Analysis Tools

- ◇ Antivirus scanners
- ◇ Sandbox environments
- ◇ VirusTotal
- ◇ System monitoring tools

13. Logic Bomb

A Logic Bomb is a type of malicious code that stays hidden in a system and activates only when a specific condition is met.

Simple: A logic bomb = Hidden malicious code triggered by an event or condition.

How It Works

The code remains inactive until a trigger occurs, such as:

- A certain date or time
- A user account is deleted

- A file is opened
- A specific number of logins occurs
- A program is executed

Example

An employee secretly adds code that says:
"If today is January 1st, delete all company files."

The code does nothing until January 1st, then it activates and causes damage.

Characteristics

Feature	Description
Hidden	Remains inactive for a period of time.
Triggered	Activates when a condition is met.
Malicious	Causes damage, deletes data, or disrupts systems.
Difficult to detect	May appear as normal code until triggered.

Common Effects

- Delete files
- Corrupt data
- Disable systems
- Leak information
- Disrupt business operations

Prevention

- ◇ Review source code regularly.
- ◇ Use access controls.
- ◇ Monitor employee activities.
- ◇ Use antivirus and security monitoring tools.
- ◇ Maintain backups.

14. Prevention & Detection

Prevention

- ◇ Install antivirus software.
- ◇ Keep software updated.
- ◇ Download software only from trusted sources.
- ◇ Avoid suspicious email attachments and links.
- ◇ Back up important files regularly.
- ◇ Use strong passwords and MFA.

Detection

Signs of malware infection:

- ◇ Slow computer performance.
- ◇ Frequent pop-up ads.
- ◇ Unknown programs running.
- ◇ Files missing or encrypted.
- ◇ High CPU or network usage.

Summary

Malware Types

- ◇  Virus → Needs a host file and user action.
- ◇  Worm → Spreads automatically.
- ◇  Trojan → Disguised as legitimate software.
- ◇  Spyware → Steals user information.
- ◇  Adware → Displays unwanted ads.
- ◇  Rootkit → Hides malware and gives attacker control.
- ◇  Keylogger → Records keystrokes.
- ◇  Botnet → Network of infected computers.
- ◇  Ransomware → Encrypts files for ransom.
- ◇  Fileless Malware → Runs in memory without creating files.

Prevention

- ◇ Antivirus
- ◇ Software updates
- ◇ Trusted downloads
- ◇ Backups
- ◇ Strong passwords
- ◇ MFA

Memory Tips

Malware Types (Easy Mnemonic)

"**Very Wise Tigers Spy Around Running Fast**"

- ◇ **V** → Virus
- ◇ **W** → Worm
- ◇ **T** → Trojan
- ◇ **S** → Spyware
- ◇ **A** → Adware
- ◇ **R** → Rootkit
- ◇ **F** → Fileless Malware

(Also remember: Keylogger, Botnet, and Ransomware are major malware types.)

Prevention

AUBBS

- ◇ **A** → Antivirus
- ◇ **U** → Update software
- ◇ **B** → Backup data
- ◇ **B** → Beware of suspicious emails/downloads
- ◇ **S** → Strong passwords + MFA

Part 4: Threat Actors & Attack Vectors

1. Threat Actors

Threat actors are **people, groups, or organizations** that carry out cyber attacks to steal data, disrupt systems, or gain unauthorized access.

Common Motives

- 💰 Financial gain
- 🕵️ Espionage (spying)
- 🏭 Disruption or sabotage
- 🗳️ Political or ideological reasons
- 😡 Personal challenge or revenge

2. Hackers

A **hacker** is a person with computer skills who accesses systems. Hackers can be ethical or malicious.

🟢 White Hat Hacker (Ethical Hacker)

- ◇ Works **with permission**.
- ◇ Finds and fixes security vulnerabilities.
- ◇ Helps improve security.

Example: A company hires a hacker to test its website.

🔴 Black Hat Hacker

- ◇ Works **without permission**.
- ◇ Steals data or damages systems.
- ◇ Performs illegal cyber attacks.

Example: Stealing credit card information.

- Gray Hat Hacker

- ◇ Accesses systems **without permission**, but usually **without harmful intent**.

- ◇ Often reports vulnerabilities after discovering them.

Example: Finding a security flaw and informing the company.

3. Insider Threats

Meaning

An **insider threat** comes from someone **inside an organization** who has legitimate access.

Examples

- ◇ Employee

- ◇ Contractor

- ◇ Former employee

Prevention way

PAM (Privileged Access Management)

What is PAM?

PAM (Privileged Access Management) is a security system that **controls, monitors, and protects privileged (administrator) accounts**.

Simple: PAM = Protecting and managing admin accounts.

What are Privileged Accounts?

These are accounts with **high-level permissions**, such as:

- Administrator (Admin)
- Root (Linux)
- System Administrator
- Database Administrator (DBA)
- Cloud Administrator

These accounts can:

- ◇ Install software
- ◇ Change system settings
- ◇ Create or delete users
- ◇ Access sensitive data

Why is PAM Important?

If an attacker steals an admin account, they can:

- ◇ × Take control of the system
- ◇ × Steal sensitive data
- ◇ × Install malware
- ◇ × Delete important files
- ◇ × Create new administrator accounts

PAM helps prevent this.

Main Features of PAM

- ◇ Secure privileged passwords
- ◇ Control who can use admin accounts
- ◇ Record and monitor admin activities
- ◇ Grant temporary privileged access
- ◇ Enforce Multi-Factor Authentication (MFA)

Example

Without PAM:

- ◇ An administrator password is shared among employees.

With PAM:

- ◇ The password is stored securely.
- ◇ Only authorized users can access it.
- ◇ Every admin action is recorded.
- ◇ The password can be changed automatically after use.

Benefits

- ◇ Protects administrator accounts.
- ◇ Reduces insider threats.
- ◇ Prevents unauthorized access.
- ◇ Improves security auditing.
- ◇ Helps organizations meet security compliance requirements.

Quick Summary

PAM (Privileged Access Management) is used to:

- ◇ Protect administrator accounts.
- ◇ Control privileged access.
- ◇ Monitor admin activities.
- ◇ Reduce the risk of cyber attacks.

Memory Trick

PAM = Protect Admin Management

Think:

PAM → Protects Powerful Accounts.

Exam Tip

Definition:

Privileged Access Management (PAM) is a cybersecurity solution that secures, controls, and monitors access to privileged accounts (such as administrator or root accounts) to prevent unauthorized use and reduce security risks.

Note: In Linux, **PAM** can also mean **Pluggable Authentication Modules**, an authentication framework used by services like login, SSH, and `sudo`. In general cybersecurity discussions, **PAM** usually refers to **Privileged Access Management**, while in Linux administration, it usually refers to **Pluggable Authentication Modules**. The correct meaning depends on the context.

Risks

- ◇ Data theft
- ◇ Data leaks
- ◇ System sabotage

Example: An employee copies confidential company files before leaving the job.

4. Nation-State Attacks

Meaning

Cyber attacks carried out or supported by a **government** against another country or organization.

Targets

- ◇ Government agencies
- ◇ Military systems
- ◇ Critical infrastructure
- ◇ Financial institutions

Purpose

- ◇ Espionage

◇ Cyber warfare

◇ Disruption

5. Cybercriminal Organizations

Meaning

Groups of criminals who use cyber attacks to make money.

Activities

◇ Ransomware attacks

◇ Identity theft

◇ Online fraud

◇ Selling stolen data

Example: A criminal group demanding ransom after encrypting company files.

6. Attack Vectors

Meaning

An **attack vector** is the **method or path** an attacker uses to gain unauthorized access to a system.

7. Phishing

Meaning

A phishing attack tricks users into revealing sensitive information.

Common Targets

◇ Passwords

◇ Bank details

◇ Credit card numbers

Example

A fake email pretending to be from a bank asking you to log in.

8. Social Engineering

Meaning

Manipulating people into revealing confidential information or performing unsafe actions.

Examples

- ◇ Fake phone calls
- ◇ Fake emails
- ◇ Fake websites
- ◇ Impersonation

Example: Someone pretending to be IT support asks for your password.

9. Password Attacks

Meaning

Attempts to steal or guess user passwords.

Common Types

- ◇ Brute-force attack
- ◇ Dictionary attack
- ◇ Credential stuffing
- ◇ Password spraying

Prevention

- ◇ Strong passwords
- ◇ Multi-Factor Authentication (MFA)

10. Web Attacks

Meaning

Attacks that target websites or web applications.

Common Examples

- ◇ SQL Injection (SQLi)
- ◇ Cross-Site Scripting (XSS)
- ◇ Cross-Site Request Forgery (CSRF)

Goal

- ◇ Steal data
- ◇ Modify websites
- ◇ Gain unauthorized access

11. Network Attacks

Meaning

Attacks that target computer networks and network devices.

Common Examples

- ◇ Denial-of-Service (DoS)
- ◇ Distributed Denial-of-Service (DDoS)
- ◇ Man-in-the-Middle (MitM)
- ◇ Packet sniffing

Goal

- ◇ Interrupt services
- ◇ Steal network traffic
- ◇ Gain network access

Quick Summary

Threat Actors

- ◇ White Hat → Ethical hacker
- ◇ Black Hat → Malicious hacker
- ◇ ◦ Gray Hat → Unauthorized but usually non-malicious
- ◇ Insider Threat → Trusted person inside the organization
- ◇ Nation-State → Government-sponsored attacker
- ◇ Cybercriminal Organization → Criminal group seeking profit

Attack Vectors

- ◇ Phishing → Fake emails/messages
- ◇ Social Engineering → Manipulating people
- ◇ Password Attacks → Guessing or stealing passwords
- ◇ Web Attacks → Attacks on websites and web apps
- ◇ Network Attacks → Attacks on computer networks

Memory Tips

Hacker Types

WBG

- ◇ **W** → White Hat (Ethical)
- ◇ **B** → Black Hat (Malicious)
- ◇ **G** → Gray Hat (In between)

Common Attack Vectors

PSPWN

- ◇ **P** → Phishing
- ◇ **S** → Social Engineering
- ◇ **P** → Password Attacks
- ◇ **W** → Web Attacks
- ◇ **N** → Network Attacks

Easy rule to remember:

Threat Actor = Who attacks

Attack Vector = How they attack

Part 5: Cyber Kill Chain

1. What is the Cyber Kill Chain?

The **Cyber Kill Chain** is a cybersecurity model that describes the **seven stages of a cyber attack**. It helps security teams understand, detect, and stop attacks before they succeed.

Simple: The Cyber Kill Chain = **The step-by-step process an attacker follows to compromise a system.**

2. Reconnaissance 🔍

Meaning

The attacker gathers information about the target before launching an attack.

Activities

- Collect email addresses
- Find IP addresses
- Scan networks
- Research employees on social media

Example: An attacker searches a company's website to find employee email addresses.

3. Weaponization

Meaning

The attacker creates or prepares a malicious payload to exploit the target.

Examples

- ◇ Malware
- ◇ Virus
- ◇ Trojan
- ◇ Malicious document

Example: Embedding malware inside a fake PDF file.

4. Delivery

Meaning

The attacker sends the malicious payload to the victim.

Common Methods

- ◇ Phishing email
- ◇ Malicious website
- ◇ USB drive

- ◇ File download

Example: Sending an infected email attachment.

5. Exploitation

Meaning

The malicious code exploits a vulnerability to gain access to the system.

Examples

- ◇ Software vulnerability
- ◇ Weak password
- ◇ Unpatched operating system

Example: A user opens an infected attachment, allowing malware to run.

6. Installation

Meaning

The malware installs itself on the victim's computer.

Purpose

- ◇ Maintain access
- ◇ Hide from detection
- ◇ Continue malicious activities

Example: Installing ransomware on the victim's computer.

7. Command & Control (C2) 01F310

Meaning

The infected system communicates with the attacker's server to receive commands.

Purpose

- ◇ Control infected devices
- ◇ Send stolen information
- ◇ Download more malware

Example: Malware connects to a remote server controlled by the attacker.

8. Actions on Objectives

Meaning

The attacker performs the final goal of the attack.

Common Objectives

- ◇ Steal sensitive data
- ◇ Encrypt files (Ransomware)
- ◇ Destroy data
- ◇ Spy on users
- ◇ Disrupt services

Example: Encrypting company files and demanding a ransom.

9. MITRE ATT&CK Overview

Meaning

MITRE ATT&CK is a cybersecurity framework that lists **real-world attacker techniques and tactics** used during cyber attacks.

Purpose

- ◇ Understand attacker behavior.
- ◇ Improve detection.
- ◇ Strengthen defenses.
- ◇ Support incident response.

Simple: MITRE ATT&CK is a knowledge base of **how attackers operate**.

10. Detection Opportunities

Security teams can detect or stop an attack at every stage.

Stage	Example Detection
Reconnai-ssance	Monitor scans and unusual traffic
Weaponiz-ation	Malware analysis
Delivery	Email filtering
Exploitati-on	Patch vulnerabil-ities
Installatio-n	Antivirus/ EDR alerts
Command & Control	Firewall and network monitorin-g
Actions on Objectives	Data loss prevention and incident response

Quick Summary

Cyber Kill Chain Stages

1.  **Reconnaissance** → Gather information.
2.  **Weaponization** → Prepare malware.
3.  **Delivery** → Send the malware.
4.  **Exploitation** → Exploit a vulnerability.

5. 🖥️ **Installation** → Install malware.
6. 📡 **Command & Control (C2)** → Communicate with the attacker.
7. 🎯 **Actions on Objectives** → Complete the attack.

MITRE ATT&CK

- ◇ Documents attacker tactics and techniques.
- ◇ Helps organizations detect and defend against cyber attacks.

Detection Opportunities

- ◇ Firewalls
- ◇ Antivirus/EDR
- ◇ Email filtering
- ◇ Network monitoring
- ◇ Security monitoring (SIEM)
- ◇ Regular software updates and patching

Memory Tips

Cyber Kill Chain

RWDEICO

- ◇ **R** → Reconnaissance
- ◇ **W** → Weaponization
- ◇ **D** → Delivery
- ◇ **E** → Exploitation

◇ **I** → Installation

◇ **C** → Command & Control

◇ **O** → Objectives

Easy Sentence

"Recon → Weaponize → Deliver → Exploit → Install → C2 → Objective"

Easy rule to remember:

Cyber Kill Chain = The attacker's roadmap.

MITRE ATT&CK = The attacker's playbook.

Part 6: Real-World Case Studies (Basic Important Notes)

1. WannaCry (2017)

What Happened?

WannaCry was a ransomware attack that encrypted files and demanded payment to restore access.

Impact

- Affected over **150 countries**.
- Infected hundreds of thousands of computers.
- Disrupted hospitals, businesses, and government organizations.

Lesson

- ◇ Keep systems updated.
- ◇ Back up important data.
- ◇ Patch security vulnerabilities.

2. NotPetya (2017)

What Happened?

NotPetya appeared to be ransomware but was mainly designed to **destroy data**.

Impact

- ◇ Spread rapidly across networks.
- ◇ Caused billions of dollars in damage.
- ◇ Disrupted many global companies.

Lesson

- ◇ Segment networks.
- ◇ Keep software updated.
- ◇ Maintain reliable backups.

3. Stuxnet (2010)

What Happened?

Stuxnet was a sophisticated worm that targeted industrial control systems.

Impact

- ◇ Damaged industrial equipment.
- ◇ Showed that malware can affect physical infrastructure.

Lesson

- ◇ Protect critical infrastructure.
- ◇ Secure industrial systems.
- ◇ Regularly monitor networks.

4. SolarWinds (2020)

What Happened?

Attackers compromised a trusted software update, allowing them to access many organizations.

Impact

- ◇ Affected government agencies and private companies.
- ◇ One of the largest supply chain attacks.

Lesson

- ◇ Secure the software supply chain.
- ◇ Monitor software updates.
- ◇ Verify trusted applications.

5. Equifax Data Breach (2017)

What Happened?

Hackers exploited an unpatched software vulnerability and stole sensitive customer data.

Impact

- ◇ Personal information of millions of people was exposed.

Lesson

- ◇ Apply security patches quickly.
- ◇ Protect sensitive data.
- ◇ Continuously monitor systems.

6. Colonial Pipeline (2021)

What Happened?

A ransomware attack disrupted fuel distribution operations.

Impact

- ◇ Temporary fuel shortages.
- ◇ Major business disruption.

Lesson

- ◇ Use Multi-Factor Authentication (MFA).
- ◇ Maintain backups.
- ◇ Prepare an incident response plan.

7. Yahoo Data Breach (2013-2014)

What Happened?

Hackers gained unauthorized access to Yahoo user accounts.

Impact

- ◇ Billions of user accounts were affected.
- ◇ Names, email addresses, and passwords were exposed.

Lesson

- ◇ Use strong passwords.
- ◇ Enable MFA.
- ◇ Detect attacks early.

8. Lessons Learned

These attacks teach important cybersecurity lessons:

- ◇ o00000 Keep software updated.
- ◇ o0000w Back up important data.
- ◇ o0000T000o0000 Train employees about cyber threats.
- ◇ o00000 Monitor systems continuously.
- ◇ o00000 Apply security patches promptly.
- ◇ o00000 Use strong passwords and MFA.
- ◇ o00000 Secure networks and systems.
- ◇ T00n Respond quickly to incidents.

9. Incident Response

Meaning

Incident Response is the process of detecting, managing, and recovering from a cyber attack.

Basic Steps

1.    Preparation
2.    Detection
3.   Containment
4.  Eradication
5.    Recovery
6.    Lessons Learned

Goal

Reduce damage and restore normal operations as quickly as possible.

Quick Summary

Famous Cyber Attacks

- ◇ WannaCry Ransomware
- ◇ NotPetya Destructive malware
- ◇ Stuxnet Industrial systems attack
- ◇ SolarWinds Supply chain attack
- ◇ Equifax Data breach
- ◇ Colonial Pipeline Ransomware attack
- ◇ o Yahoo Massive data breach

Key Lessons

- ◇ Update software.
- ◇ Patch vulnerabilities.
- ◇ Back up data.
- ◇ Use MFA.
- ◇ Train employees.
- ◇ Monitor systems.
- ◇ Respond quickly to incidents.

o Memory Tips

Famous Attacks (Easy Order)

- ◇ **W**annaCry

- ◇ **N** NotPetya
- ◇ **S** Stuxnet
- ◇ **S** SolarWinds
- ◇ **E** Equifax
- ◇ **C** Colonial Pipeline
- ◇ **Y** Yahoo

Incident Response

PDCERL

- ◇ **P** Preparation
- ◇ **D** Detection
- ◇ **C** Containment
- ◇ **E** Eradication
- ◇ **R** Recovery
- ◇ **L** Lessons Learned

Easy rule to remember:

Study past cyber attacks to prevent future ones. Each major incident teaches valuable security lessons that improve defenses.

01F4D8 Part 7: Defense in Depth & Security Best Practices (Basic Important Notes)

1. Defense in Depth

Meaning

Defense in Depth is a security strategy that uses **multiple layers of protection**. If one security layer fails, the others continue to protect the system.

Simple: Never rely on only one security control.

2. Layered Security

Security is stronger when multiple controls work together.

Common Security Layers

- 🛡️ Firewall
- 🦠 Antivirus/EDR
- 🚦 IDS/IPS
- 📠 Multi-Factor Authentication (MFA)
- 🌐 VPN
- 🔒 Encryption
- 💾 Backups
- 🧠 Security Awareness Training

3. Firewall

Meaning

A **firewall** monitors and controls incoming and outgoing network traffic.

Purpose

- ◇ Block unauthorized access.
- ◇ Allow trusted network traffic.

4. Antivirus & EDR

Antivirus

Detects and removes viruses and other malware.

EDR (Endpoint Detection and Response)

Monitors devices for suspicious activity and responds to threats.

Difference: Antivirus mainly **detects and removes malware**, while **EDR continuously monitors, detects, and responds to advanced attacks**.

5. IDS & IPS

IDS (Intrusion Detection System)

Detects suspicious or malicious activity and sends alerts.

IPS (Intrusion Prevention System)

Detects and **automatically blocks** malicious activity.

Easy Memory

◇ **IDS = Detect**

◇ **IPS = Prevent**

6. VPN (Virtual Private Network)

Meaning

A **VPN** creates a secure, encrypted connection over the Internet.

Benefits

◇ Protects privacy.

◇ Secures data transmission.

◇ Hides your IP address.

7. Multi-Factor Authentication (MFA)

Meaning

MFA requires **two or more verification methods** before granting access.

Examples

- ◇ Password + OTP
- ◇ Password + Fingerprint
- ◇ Password + Face Recognition

Benefit

Makes it much harder for attackers to access accounts.

8. Zero Trust

Meaning

Zero Trust follows the rule:

"Never trust, always verify."

Principles

- ◇ Verify every user.
- ◇ Verify every device.
- ◇ Grant the minimum required access.

9. Network Segmentation

Meaning

Divide a network into smaller sections to reduce the spread of attacks.

Benefit

If one section is compromised, the attacker cannot easily reach the rest of the network.

10. Security Policies

Meaning

Written rules that explain how users should protect systems and data.

Examples

- ◇ Password policy
- ◇ Acceptable Use Policy (AUP)
- ◇ Data protection policy
- ◇ Backup policy

11. Security Awareness Training

Meaning

Training users to recognize and avoid cyber threats.

Topics

- ◇ Phishing
- ◇ Password safety
- ◇ Safe web browsing
- ◇ Social engineering

Goal

Reduce human errors.

12. Backup & Disaster Recovery

Backup

Creating copies of important data.

Disaster Recovery

Restoring systems and data after an attack or disaster.

Benefits

- ◇ Prevents permanent data loss.
- ◇ Speeds up recovery.

13. Incident Response

Meaning

The process of detecting, containing, and recovering from cyber attacks.

Basic Steps

1. Preparation
2. Detection
3. Containment
4. Eradication
5. Recovery
6. Lessons Learned

14. Security Auditing

Meaning

A security audit checks whether security controls and policies are working properly.

Purpose

- ◇ Find vulnerabilities.
- ◇ Ensure compliance.
- ◇ Improve security.

15. Best Practices

- ◇  Use strong, unique passwords.
- ◇  Enable MFA.
- ◇  Keep software updated.

- ◇ 01F510 Encrypt sensitive data.
- ◇ 01F48E Back up files regularly.
- ◇ 01F440 Monitor systems continuously.
- ◇ 01F4DC Follow security policies.
- ◇ 01F4E7 Be cautious of suspicious emails and links.

01F4CC Quick Summary

Defense in Depth

Use **multiple layers of security** to protect systems.

Security Layers

- ◇ 🛡 Firewall
- ◇ 01F9A0 Antivirus & EDR
- ◇ 01F6A8 IDS & IPS
- ◇ 01F310 VPN
- ◇ 01F511 MFA
- ◇ 🗝 Encryption
- ◇ 01F48E Backups
- ◇ 01F01F4683EB Security Awareness Training

Common Threats

- ◇ 01F9A0 Malware
- ◇ 01F3A3 Phishing

- ◇  Ransomware
- ◇  Password Attacks
- ◇  Social Engineering

Security Tools

- ◇ Firewall
- ◇ Antivirus
- ◇ VPN
- ◇ MFA
- ◇ Encryption
- ◇ IDS/IPS
- ◇ EDR

Memory Tricks

CIA

- ◇ **C** → Confidentiality
- ◇ **I** → Integrity
- ◇ **A** → Availability

TPPH

- ◇ **T** → Technology
- ◇ **P** → Processes
- ◇ **P** → Policies

◇ **H** → Human Awareness

IDS vs IPS

◇ **IDS = Detect**

◇ **IPS = Prevent**

Defense in Depth

"Many layers = Better security."

Cyber Kill Chain

Recon → Weaponize → Deliver → Exploit → Install → C2 → Objective

Easy Rule to Remember:

No single security tool is enough. Strong cybersecurity combines **people, processes, policies, and multiple layers of technology** to protect systems and data.